

Narrativa explicativa – GQM + PRAGMATIC aplicado a CRA

1. Del regulador al bit: por qué GQM

El CRA habla el idioma de los requisitos, los procedimientos y las obligaciones. Las redes, los dispositivos y las personas hablan, en cambio, el idioma de los logs, los parches, las incidencias y las facturas. Entre ambos mundos hay un abismo semántico que, si no se llena de algo mejor, tiende a llenarse de powerpoints.

GQM es, en esencia, una forma disciplinada de tender un puente: empezamos por los **objetivos** (qué quiere lograr el país con el CRA), seguimos con las **preguntas** que debemos poder responder para saber si avanzamos, y terminamos en las **métricas** que convierten esas preguntas en algo medible. No es una teoría metafísica: es una manera de asegurarse de que cada dato tiene un propósito, y cada propósito, una traducción en datos.

2. Por qué PRAGMATIC (y por qué en mayúsculas)

Una vez que aceptamos que vamos a medir cosas, queda la cuestión incómoda: ¿qué tan buenas son nuestras métricas? No todas las cifras son iguales. Algunas predicen, otras sólo decoran. Algunas inspiran acción, otras se imprimen en informes que nadie lee.

Los criterios PRAGMATIC nos obligan a mirar a cada métrica de frente:

- ¿Predice algo útil o sólo describe el pasado?
- ¿Es realmente relevante para los objetivos CRA o simplemente “interesante”?
- ¿Puede activar decisiones concretas?
- ¿Mide lo que dice medir, con precisión razonable, en el momento en que hace falta?
- ¿Es independiente de los sesgos más obvios?
- ¿Compensa el esfuerzo necesario para obtenerla?

No buscamos el 10 en todas las categorías; buscamos entender el perfil de cada métrica para usarla con conocimiento de causa.

3. Cómo encajan los indicadores CRA en GQM

En el informe de indicadores CRA se identificaban varias familias de métricas: cobertura de productos conformes, gestión de vulnerabilidades, incidentes y tiempos de respuesta, impacto económico, capacidades institucionales y capital humano.

GQM nos fuerza a hacer explícito:

- Qué objetivo nacional sirve cada familia. Por ejemplo, reducir la “deuda de vulnerabilidades” o aumentar la proporción de productos certificados en infraestructuras críticas.
- Qué preguntas concretas responde. ¿Estamos parcheando más rápido que el año pasado? ¿Se están notificando incidentes en plazo? ¿El sector X está sistemáticamente peor que el Y?
- Qué métricas específicas necesitamos. TTP, porcentaje de parches aplicados a tiempo, edad de las vulnerabilidades explotadas, nº de certificados EUCC, etc.

Este ejercicio de explicitación tiene un efecto colateral saludable: algunas métricas que parecían inevitables desaparecen, porque no responden a ninguna pregunta relevante. Y otras, que nadie miraba, aparecen como cruciales.

4. Qué nos enseña PRAGMATIC de estas métricas

Al aplicar PRAGMATIC a los indicadores CRA, emergen varias observaciones útiles:

- Las métricas relacionadas con vulnerabilidades y parches (tiempo hasta parche, porcentaje de instalaciones actualizadas, antigüedad de vulnerabilidades explotadas) tienden a puntuar muy alto en Predictivo, Relevante, Accionable y Significativo, aunque su medición no sea trivial.
- Los indicadores de impacto macroeconómico (pérdidas como % del PIB o del valor añadido sectorial) son muy significativos para el discurso político y estratégico, pero más débiles en Precisión y Rentabilidad: exigen modelos y asunciones que conviene tratar con humildad.
- Las métricas de capital humano y capacidad institucional (número de profesionales, vacantes, inspecciones, tiempos de tramitación) son relativamente fáciles de obtener y muy útiles para políticas de medio plazo, aunque su vínculo con el CRA sea más indirecto que el de un TTP.
- Algunas métricas muy intuitivas, como el número bruto de incidentes, necesitan contextualización para no convertirse en fuegos artificiales estadísticos: más incidentes reportados pueden ser síntoma de mayor transparencia, no necesariamente de mayor riesgo.

Este mapa PRAGMATIC no pretende descalificar métricas, sino ayudarnos a decidir en cuáles merece la pena invertir primero, cuáles conviene pilotar y cuáles should remain optional.

5. Cómo usar este marco en España (y más allá)

Un Estado miembro —o un consorcio sectorial— puede utilizar el marco GQM+PRAGMATIC de la siguiente manera:

1. Seleccionar objetivos prioritarios (por ejemplo, G2 y G3 en sectores críticos durante los primeros años de vigencia del CRA).
2. Elegir un subconjunto de métricas de alta puntuación PRAGMATIC para componer el cuadro de mando nacional/sectorial.
3. Definir fuentes de datos y responsabilidades: qué datos proporcionan las autoridades nacionales, qué datos proporcionan fabricantes, operadores, aseguradoras o centros de respuesta.
4. Arrancar con un núcleo de métricas “core” y un anillo de métricas “experimentales”, aceptando que algunas pasarán el corte y otras se quedarán como curiosidades.
5. Revisar anualmente la cartera de métricas, ajustando en función de la experiencia, la disponibilidad de datos y la evolución de la regulación.

Nada impide que otros países fuera de la UE adopten el mismo enfoque: al fin y al cabo, las vulnerabilidades no piden pasaporte. Pero en el contexto CRA, este tipo de marco es especialmente valioso para comparar manzanas con manzanas entre Estados miembros y sectores.

6. Un apunte sobre honestidad y límites

La tentación de hacer de las métricas un nuevo fetiche es real. Un dashboard bien coloreado invita a creer que el mundo está bajo control. La realidad, por desgracia, es analógica, ruidosa y tozuda.

Por eso, este marco insiste en dos ideas:

- Ninguna métrica, por buena que sea, sustituye al juicio experto.
- Ningún conjunto de métricas, por completa que parezca, agota la complejidad del ecosistema CRA.

El objetivo razonable no es tener todos los números posibles, sino **tener los números adecuados para las conversaciones que importan**: entre fabricantes y reguladores, entre operadores críticos y proveedores, entre responsables políticos y ciudadanos.

Si al final de aplicar GQM+PRAGMATIC descubrimos que necesitamos menos métricas, pero mejores, el ejercicio habrá merecido la pena.